

GUARROMAN.LOCAL

Infraestructura de Red, Bastionado y Plan de Seguridad

Ayuntamiento de Guarromán + Casa de la Cultura

Blue Team / Red Team · Simulación CTF ·
Ciclo Formativo Especialización Ciber— Práctica de Redes y Ciberseguridad

1. Topología de Red

La infraestructura está dividida en dos sedes: el Ayuntamiento (sede principal) y la Casa de la Cultura (sede secundaria), interconectadas mediante una VPN WireGuard.

1.1 Ayuntamiento — Interfaces JSBach

Interfaz	IP / Red	Función
vpn	10.200.0.1	Interfaz VPN
enp6s0(WAN)	172.29.230.160	Puerta Enlace ISP
br01	10.1.1.1/24	Red troncal — Conecta Switch 1 y Switch 2
br03	10.1.3.1/24	Gateway VLAN 3 — Active Directory
br04	10.1.4.1/24	Gateway VLAN 4 — SOC (Wazuh + Suricata)
br05	10.1.5.1/24	Gateway VLAN 5 — Trabajo
br06	10.1.6.1/24	Gateway VLAN 6 — Trabajo
wlp5s0	10.1.99.1/24	WiFi — Red interna

1.2 Ayuntamiento — Switches

Dispositivo	IP Gestión	Puertos activos	VLANs asignadas
Switch 1	10.1.1.11/24	P3 → VLAN 3 (AD) P4 → VLAN 4 (SOC) P8 → JSBach br01	VLAN 3, VLAN 4
Switch 2	10.1.1.12/24	P5 → VLAN 5 (Trabajo) P6 → VLAN 6 (Trabajo) P8 → JSBach br01	VLAN 5, VLAN 6

1.3 Ayuntamiento — VLANs

VLAN	Red	Función	Equipos
VLAN 2 (DMZ)	10.1.2.0/24	Zona desmilitarizada	Apache2 + WordPress (con vulnerabilidades)
VLAN 3	10.1.3.0/24	Active Directory	Windows Server 2016 — GUARROMAN.LOCAL
VLAN 4	10.1.4.0/24	SOC	Wazuh SIEM + Suricata IDS/IPS
VLAN 5	10.1.5.0/24	Trabajo	Equipos de usuarios
VLAN 6	10.1.6.0/24	Trabajo	Equipos de usuarios
WiFi	10.1.99.0/24	Red WiFi independiente	Windows (sin VLAN)

1.4 Casa de la Cultura — Interfaces JSBach

Interfaz	IP / Red	Función
vpn	10.200.0.1	Interfaz VPN
enp5s0	172.29.230.161	Puerta Enlace ISP
br01	10.2.1.1/24	Red troncal — conecta el Switch
br015	10.2.15.1/24	Gateway VLAN 15 — Trabajo CC
br016	10.2.16.1/24	Gateway VLAN 16 — Trabajo CC
wlp4s0	10.2.99.1/24	WiFi CC — Red independiente

1.5 Casa de la Cultura — Switch y VLANs

Dispositivo / VLAN	IP / Red	Puertos / Función
Switch CC	10.2.1.2/24	P 2-4 → VLAN 15 P 5-7 → VLAN 16 P 8 → JSBach br01
VLAN 15	10.2.15.0/24	Equipos de trabajo Casa de la Cultura
VLAN 16	10.2.16.0/24	Equipos de trabajo Casa de la Cultura
WiFi CC	10.2.99.0/24	Red WiFi independiente

1.6 Interconexión entre sedes

Las dos sedes están interconectadas mediante VPN WireGuard gestionada desde el Router JSBach. La Casa de la Cultura usa el Active Directory del Ayuntamiento (GUARROMAN.LOCAL) a través de este túnel VPN. El tráfico entre sedes viaja cifrado por Internet.

Elemento	Detalle
Tecnología VPN	WireGuard
Gestión	JSBach (ambos extremos)
AD utilizado	GUARROMAN.LOCAL (Ayuntamiento)
Dominio CC	Accede al AD del Ayto mediante VPN

2. Análisis de Riesgos

Se identifican los siguientes riesgos ordenados por criticidad:

ID	Riesgo	Activo afectado	Criticidad	Vector
R01	Windows en WiFi sin VLAN ni filtrado	10.1.99.0/24	CRÍTICA	Acceso lateral a toda la red
R02	Apache2/WordPress con vulnerabilidades en DMZ	10.1.2.0/24	ALTA	RCE, SQLi, XSS, LFI
R03	Windows Server 2016 sin soporte extendido	10.1.3.0/24	ALTA	Kerberoasting, Pass-the-Hash
R04	Suricata en modo IDS (solo alerta, no bloquea)	VLAN 4	MEDIA	Intrusiones no bloqueadas
R05	Interconexión VPN sin segmentación adicional CC	10.200.0.1	MEDIA	Pivoting desde CC a Ayto
R06	Agentes Wazuh no instalados en todos los equipos	Global	MEDIA	Punto ciegos en monitorización
R07	Switches sin autenticación 802.1X	SW1, SW2	MEDIA	VLAN hopping
R08	Credenciales por defecto en switches	SW1, SW2	MEDIA	Acceso no autorizado

3. Plan Blue Team — Bastionado por Capas

El bastionado se aplica siguiendo el modelo de defensa en profundidad, desde el perímetro hasta los endpoints.

3.1 Capa 1— Router JSBach (Linux)

- Deshabilitar el reenvío IP para redes no autorizadas: iptables -P FORWARD DROP como política base.
- Aplicar reglas de iptables que aíslen la WiFi (wlp5s0) del resto de interfaces bridge.
- Activar rp_filter=1 para evitar IP spoofing en todas las interfaces.
- Deshabilitar IPv6 si no se usa: net.ipv6.conf.all.disable_ipv6=1.
- Instalar y configurar fail2ban para proteger el acceso SSH.
- Cambiar el puerto SSH por defecto (22 → puerto no estándar).
- Acceso SSH solo por clave pública, deshabilitar autenticación por contraseña.
- Deshabilitar el acceso root directo por SSH (PermitRootLogin no).

WireGuard VPN:

- Usar claves de 256 bits. Rotar las claves cada 90 días.
- Restringir los peers permitidos por IP de origen.
- Limitar el tráfico del túnel VPN solo a los puertos necesarios (AD: 389, 636, 88, 445).

3.2 Capa 2— Active Directory (VLAN 3 · 10.1.3.0/24)

Hardening Windows Server 2016:

- Aplicar todos los parches de seguridad disponibles (Windows Update).
- Activar Windows Defender y mantenerlo actualizado.
- Configurar política de contraseñas: mínimo 12 caracteres, complejidad, caducidad 90 días.
- Habilitar auditoría de eventos: inicio de sesión, cambios en cuentas, acceso a objetos.
- Deshabilitar servicios innecesarios: Telnet, FTP, NetBIOS si no se usa.
- Deshabilitar SMBv1 (vector EternalBlue): Set-SmbServerConfiguration -EnableSMB1Protocol \$false
- Configurar Fine-Grained Password Policy para cuentas de administrador.
- Limitar usuarios con privilegios de Domain Admin al mínimo necesario.
- Activar el registro de eventos de seguridad y enviarlos a Wazuh.

Protección frente a ataques Kerberos:

- Proteger las cuentas de servicio con contraseñas de más de 25 caracteres (anti-Kerberoasting).
- Activar AES256 para tickets Kerberos, deshabilitar RC4.
- Configurar Protected Users Security Group para las cuentas privilegiadas.

3.3 Capa 3— DMZ (VLAN 2 · 10.1.2.0/24 — Apache2/WordPress)

⚠ **Este servidor tiene vulnerabilidades intencionadas. Es el target principal del Red Team rival.**

Medidas de contención:

- Asegurar que la DMZ NO puede iniciar conexiones hacia las VLANs internas (regla iptables).
- Aplicar WAF (ModSecurity) en Apache2 para filtrar ataques web comunes (SQLi, XSS, LFI).
- Mantener logs de Apache enviados a Wazuh en tiempo real.
- Configurar fail2ban en el servidor Apache para bloquear IPs que hacen fuerza bruta.
- Instalar agente Wazuh en el servidor Apache para monitorización de integridad de ficheros (FIM).
- Deshabilitar directory listing en Apache (Options -Indexes).
- Actualizar WordPress al máximo, eliminar plugins y temas no usados.
- Cambiar el prefijo de tablas de WordPress (wp_ por defecto → valor aleatorio).

3.4 Capa 4— SOC (VLAN 4 · 10.1.4.0/24 — Wazuh + Suricata)

Configuración Wazuh:

- Instalar agente Wazuh en: Windows Server AD, Apache2, JSBach (Linux), switches (syslog).
- Activar módulos: File Integrity Monitoring (FIM), Vulnerability Detector, Log Analysis.
- Configurar alertas para: intentos de login fallidos (>5 en 1 min), cambios en ficheros críticos, escalada de privilegios.
- Integrar con los switches mediante syslog para correlacionar eventos de red con eventos de host.

Configuración Suricata:

- Cambiar a modo IPS (bloqueante) — actualmente en modo IDS es insuficiente.
- Activar rulesets: Emerging Threats, ET Pro (si disponible), reglas custom para el entorno.
- Crear regla custom para detectar escaneos Nmap contra la red interna.
- Crear alerta para tráfico desde WiFi (10.1.99.0/24) hacia VLANs internas.

3.5 Capa 5— Endpoints (VLANs 5 y 6 · Equipos Windows)

- Unir todos los equipos Windows al dominio GUARROMAN.LOCAL.
- Aplicar GPO de seguridad: deshabilitar USB, activar firewall Windows, bloquear PowerShell no firmado.
- Instalar agentes Wazuh en todos los endpoints.
- Deshabilitar acceso a SMB entre equipos de la misma VLAN si no es necesario.

3.6 Red WiFi (10.1.99.0/24) — PRIORIDAD MÁXIMA

- Crear una VLAN específica para WiFi (por ejemplo VLAN 99).
- Aplicar reglas de iptables que bloqueen todo tráfico desde el WIFI hacia VLANs 2, 3, 4, 5, 6.
- Permitir desde WIFI únicamente tráfico hacia Internet (puerto 80, 443, DNS).
- Activar Client Isolation en el AP WiFi para que los clientes no se vean entre sí.
- Activar NAT en la VLAN WiFi para aislar las IPs internas.

4. Plan Red Team — Vectores de Ataque contra el Rival

El equipo rival tiene una arquitectura similar. Los vectores de ataque se ordenan de mayor a menor probabilidad de éxito basándose en los errores de configuración más comunes en entornos de clase.

4.1 Reconocimiento (Fase 1)

Herramienta	Comando / Uso	Objetivo
Nmap	<code>nmap -sV -sC -O -p- <IP_rival></code>	Descubrir servicios y versiones
Nmap	<code>nmap --script vuln <IP_rival></code>	Escaneo de vulnerabilidades conocidas
WPScan	<code>wpscan --url http://<IP_rival> --enumerate u,p,t</code>	Enumerar WordPress (usuarios, plugins, temas)
enum4linux	<code>enum4linux -a <IP_rival></code>	Enumerar SMB, usuarios AD, shares
theHarvester	<code>theHarvester -d rival.local -b all</code>	OSINT sobre el dominio
Nikto	<code>nikto -h http://<IP_rival></code>	Escaneo de vulnerabilidades web

4.2 Explotación Web (Fase 2 — DMZ rival)

WordPress:

- Fuerza bruta en /wp-login.php con usuarios encontrados en reconocimiento.
- Explotar plugins vulnerables: buscar CVEs de los plugins instalados.
- Si se obtiene acceso al panel: subir webshell mediante tema o plugin.
- Buscar fichero wp-config.php expuesto o con backups (.bak, ~, .old).

Apache2:

- Probar LFI (Local File Inclusion): `/index.php?page=../../../../etc/passwd`
- Probar SQLi con sqlmap si hay formularios o parámetros GET/POST.
- Buscar directorios expuestos con gobuster: `gobuster dir -u http://<IP> -w /usr/share/wordlists/dirb/common.txt`

4.3 Explotación de AD (Fase 3)

Kerberoasting:

- Enumerar cuentas de servicio con SPN: `GetUserSPNs.py RIVAL.LOCAL/usuario:pass -dc-ip <IP_AD>`
- Solicitar tickets Kerberos y crackear offline con hashcat: `hashcat -m 13100 hashes.txt rockyou.txt`

AS-REP Roasting:

- Buscar usuarios sin preautenticación Kerberos: `GetNPUsers.py RIVAL.LOCAL/ -usersfile users.txt -no-pass`

Pass-the-Hash:

- Si se obtienen hashes NTLM: crackmapexec smb <IP> -u admin -H <hash>

BloodHound:

- Mapear rutas de escalada de privilegios en el AD: bloodhound-python -u usuario -p pass -d RIVAL.LOCAL -dc <IP>

4.4 Pivoting (Fase 4)

- Desde la DMZ comprometida, intentar acceso a la red interna del rival.
- Usar el equipo WiFi como pivote si está mal aislado (similar a nuestro riesgo R01).
- Probar acceso a la VPN WireGuard del rival si tiene puertos expuestos.
- Usar Metasploit port forwarding para acceder a servicios internos desde la DMZ.

4.5 Herramientas del Red Team

Categoría	Herramienta	Uso
Escaneo	Nmap, Masscan	Descubrimiento de red y puertos
Web	Burp Suite, sqlmap, Nikto, gobuster	Análisis y explotación web
WordPress	WPScan	Auditoría WordPress
AD	Impacket, BloodHound, CrackMapExec	Explotación Active Directory
Frameworks	Metasploit	Explotación general y post-explotación
Cracking	Hashcat, John the Ripper	Crackeo de hashes offline
OSINT	theHarvester, Maltego	Reconocimiento pasivo

5. Checklist de Hardening — Prioridad y Estado

#	Acción	Componente	Prioridad	Estado
1	Aislar WiFi (10.1.99.0/24) con VLAN y reglas pfSense	JSBach / pfSense	CRÍTICA	Pendiente
2	Cambiar Suricata a modo IPS (bloqueante)	SOC VLAN 4	ALTA	Pendiente
3	Instalar agente Wazuh en Apache2/WordPress	DMZ VLAN 2	ALTA	Pendiente
4	Aplicar regla DMZ: no puede iniciar conexiones a VLANs internas	pfSense	ALTA	Pendiente
5	Parchear Windows Server 2016 — todos los updates	AD VLAN 3	ALTA	Pendiente
6	Deshabilitar SMBv1 en Windows Server	AD VLAN 3	ALTA	Pendiente
7	Instalar ModSecurity (WAF) en Apache2	DMZ VLAN 2	ALTA	Pendiente
8	Configurar fail2ban en JSBach y Apache	JSBach / DMZ	MEDIA	Pendiente
9	Cambiar puerto SSH en JSBach y hardening sshd_config	JSBach	MEDIA	Pendiente
10	Instalar agentes Wazuh en todos los endpoints	VLAN 3,4,5,6	MEDIA	Pendiente
11	Rotación de claves WireGuard	pfSense VPN	MEDIA	Pendiente
12	Habilitar auditoría de eventos AD y enviar a Wazuh	AD VLAN 3	MEDIA	Pendiente
13	Activar 802.1X en switches (autenticación de puerto)	SW1, SW2	MEDIA	Pendiente
14	Cambiar credenciales por defecto de switches	SW1, SW2	MEDIA	Pendiente
15	Deshabilitar IPv6 en JSBach si no se usa	JSBach	BAJA	Pendiente
16	GeoBlocking en pfSense	pfSense	BAJA	Pendiente
17	Actualizar WordPress y plugins	DMZ VLAN 2	BAJA	Pendiente
18	Cambiar prefijo de tablas WordPress	DMZ VLAN 2	BAJA	Pendiente

6. Resumen Ejecutivo

La infraestructura de GUARROMAN.LOCAL presenta una arquitectura bien pensada para un entorno de clase, con segmentación mediante VLANs, doble sede interconectada por VPN y un SOC con Wazuh y Suricata.

Sin embargo, se han identificado puntos críticos que deben abordarse antes del ejercicio CTF:

- El equipo Windows conectado por WiFi (10.1.99.0/24) sin VLAN ni filtrado es el riesgo más grave. Un atacante que comprometa ese equipo tendría visibilidad directa al router JSBach y potencialmente a toda la red.
- El servidor Apache2/WordPress de la DMZ con vulnerabilidades intencionadas debe estar correctamente aislado para que un compromiso no permita lateral movement hacia las VLANs internas.
- Suricata debe pasar a modo IPS para que las alertas no sean solo informativas sino que bloqueen activamente el tráfico malicioso.
- El AD con Windows Server 2016 debe tener SMBv1 deshabilitado y parches al día para evitar ataques Kerberoasting y Pass-the-Hash.

Con las medidas del Plan Blue Team implementadas, la infraestructura estará en condiciones óptimas para el ejercicio. El Plan Red Team detalla los vectores de ataque más probables contra el ayuntamiento rival, priorizando WordPress, el posible equipo WiFi sin aislar y el Active Directory.